Tự dựng web app cùng Codex

Cẩm nang cho sinh viên IT, dùng Windows

Bản 04/11/2026

Bộ khung ai-app-starter · Codex · Claude Code · React · Supabase · Cloudflare

Mục lục

Bộ khung này giúp gì 3

Stack mặc định 3

Chuẩn bị tài khoản 4

Cài công cụ trên Windows 4

Cài Codex: chọn một trong ba cách 4

Tạo dự án và làm việc với agent 5

Lấy bộ khung về máy 5

Trust dự án và duyệt hook 5

Câu đầu tiên và cách trả lời 6

Mỗi mốc diễn ra thế nào 6

Quyền của agent: khi nào phải dừng đọc kỹ 6

Giới hạn miễn phí và mốc trả tiền 7

Hai sự cố có thật và cách bộ khung chặn 8

Lovable và RLS bị thiếu (2025) 8

Replit xoá database thật (07/2025) 8

Sự cố hay gặp và cách gỡ 9

Supabase báo project bị pause 9

Hết hạn mức Codex 9

Lỗi build 9

Agent đi lạc, muốn quay lại bản trước 9

Sao lưu và thử phục hồi database 9

Lỡ để lộ key 10

Thuật ngữ của stack 10

Nguồn 10

Bộ khung này giúp gì

Bạn đã biết HTML, CSS, JavaScript, có thể đã làm chút React, nhưng chưa tự dựng trọn một app có database, đăng nhập, deploy lên mạng cho người khác dùng. Codex (agent lập trình của OpenAI) viết được phần lớn code đó. Vấn đề là nếu chỉ nói "làm cho mình app X", agent sẽ đoán ý, chọn stack tuỳ hứng, viết một lèo không giải thích, và có lúc chạy lệnh nguy hiểm như `rm -rf` hay xoá database.

`ai-app-starter` là một repo template trên GitHub, không có sẵn app. Repo gồm một bộ luật cho agent (`AGENTS.md`), mẫu tài liệu dự án, lớp chặn lệnh phá huỷ cho Codex và Claude Code, vài skill, và script sao lưu database. Khi bạn kể ý tưởng, agent đi theo một luồng cố định: hỏi lại vài câu có gợi ý, đề xuất kiến trúc kèm lý do kỹ thuật và chi phí, chờ bạn đồng ý, chia việc thành mốc nhỏ, rồi làm từng mốc. Xong mốc nào, app chạy được tới đó, agent commit và chỉ ra các file chính để bạn đọc. Bạn có thể giao hết cho agent, hoặc tự viết một phần (giao diện, query, RLS policy) để học, và để agent review.

Bạn không phải đọc hết tài liệu này trước khi bắt đầu. Cách nhanh nhất là `git clone` repo, mở bằng Codex và hỏi ngay "mình mới clone về, hướng dẫn mình bắt đầu": agent tự kiểm máy và chỉ phần còn thiếu. Tài liệu này để tra khi cần.

Stack mặc định

Phần	Mặc định	Vì sao
Frontend	React + Vite + TypeScript trong `app/`	SPA build tĩnh, deploy đơn giản, không cần server riêng
Mobile, PWA	Mobile-first, `vite-plugin-pwa` (manifest, icon, service worker)	Cài được lên màn hình chính điện thoại; agent kiểm ở khổ 360×780 lẫn desktop
Database, auth, file nhỏ	Supabase (2 project dev và prod)	Postgres có sẵn auth và RLS; gọi thẳng từ frontend
Host	Cloudflare Pages	Gói free cho cả dự án thương mại, build từ GitHub
File lớn, email	R2, Resend	Chỉ thêm khi app cần

Agent được đổi stack nếu dự án cần, nhưng phải nói lý do; ví dụ bỏ PWA cho một trang quản trị chỉ dùng trên máy tính. PWA theo tài liệu `vite-plugin-pwa`: https://vite-pwa-org.netlify.app/guide/.

Tài liệu đi theo thứ tự bạn sẽ làm: chuẩn bị tài khoản, cài công cụ trên Windows, tạo dự án, làm việc với agent, quyền của agent, giới hạn gói miễn phí, hai sự cố bảo mật có thật, và cách gỡ lỗi hay gặp. Số liệu giá kiểm ngày 04/11/2026, có link nguồn; giá đổi thường xuyên, xem lại trang nguồn trước khi trả tiền.

Chuẩn bị tài khoản

Tài khoản	Dùng để	Chi phí khởi đầu
ChatGPT (gói dùng được Codex)	Chạy Codex trong app, VS Code, terminal	Theo gói bạn đang có
GitHub	Lưu code, tạo dự án từ template, nối với Cloudflare	Miễn phí
Supabase	Postgres, Auth, Storage	Miễn phí (gói Free)
Cloudflare	Host app (Cloudflare Pages)	Miễn phí

Bộ khung cũng chạy với Claude Code: file `CLAUDE.md` chỉ có một dòng `@AGENTS.md`, nên Claude Code đọc cùng bộ luật, và `.claude/settings.json` gọi cùng lớp chặn lệnh.

Ngoài tài khoản agent, chi phí chỉ phát sinh khi app lớn lên: nhiều dữ liệu, nhiều người dùng, cần backup tự động, lưu file lớn. Bảng ở chương "Giới hạn miễn phí và mốc trả tiền" ghi cụ thể từng mốc. App cá nhân hay nhóm nhỏ thường nằm gọn trong gói free của Supabase và Cloudflare.

Cài công cụ trên Windows

Cần Windows 11 (khuyến nghị) hoặc Windows 10 bản mới; tài liệu Codex ghi Windows 11 là nền hỗ trợ chính, Windows 10 ở mức "best effort". Không cần WSL: Codex chạy native trên Windows bằng PowerShell và sandbox riêng của Windows. Chỉ dùng WSL2 khi dự án cần công cụ chỉ có trên Linux. Nguồn: https://learn.chatgpt.com/docs/windows/windows-sandbox.

Cài bằng `winget` trong PowerShell:

```
winget install --id Git.Git
winget install --id OpenJS.NodeJS.LTS
winget install --id Microsoft.VisualStudioCode
winget install --id GitHub.cli
```

Cài xong đóng PowerShell, mở lại để PATH cập nhật, rồi kiểm `git --version`, `node --version` (cần 20 trở lên), `gh --version`. Chạy `gh auth login` một lần (GitHub.com, HTTPS, đăng nhập qua trình duyệt). Tài liệu Codex còn gợi ý Python và .NET SDK; bộ khung này không cần.

Nếu PowerShell báo `npm.ps1 cannot be loaded because running scripts is disabled on this system`, tài liệu Codex gợi ý `Set-ExecutionPolicy -ExecutionPolicy RemoteSigned`. Đọc giải thích của Microsoft trước khi đổi: https://learn.microsoft.com/powershell/module/microsoft.powershell.core/about/about_execution_policies.

Cài Codex: chọn một trong ba cách

Cả ba đều đăng nhập bằng tài khoản ChatGPT và dùng chung cấu hình ở `%USERPROFILE%\.codex`:

1. **App ChatGPT cho máy tính** (Microsoft Store): giao diện chat, khung review diff, terminal tích hợp. Cài qua Store hoặc `winget install --id 9PLM9XGG6VKS -s msstore`. Nguồn: https://learn.chatgpt.com/docs/windows/windows-app.

2. **Extension VS Code** `openai.chatgpt`: chat với agent ngay cạnh code. Nếu extension đứng im, tài liệu Codex gợi ý cài Visual C++ Redistributable hoặc Visual Studio Build Tools. Nguồn: https://learn.chatgpt.com/docs/ide.
3. **Codex CLI**: `npm install -g @openai/codex`, rồi chạy `codex` và đăng nhập. Nguồn: https://github.com/openai/codex.

Nên dùng app hoặc extension hằng ngày, và cài thêm CLI vì bước duyệt hook (chương sau) tài liệu chỉ mô tả cho CLI.

Docker Desktop chỉ cần khi sao lưu database (chương cuối): https://www.docker.com/products/docker-desktop/.

Tạo dự án và làm việc với agent

Lấy bộ khung về máy

Cách nhanh nhất là clone thẳng, đặt ngoài OneDrive (đồng bộ có thể khoá file khi agent đang ghi):

```
git clone https://github.com/ngocdanhx/ai-app-starter.git expense-tracker
```

Bản clone có `origin` trỏ về repo template. Agent không bao giờ push lên đó (luật trong `AGENTS.md`, và hook chặn `git push` khi `origin` còn là template). Trước lần push đầu, agent hướng dẫn tạo repo riêng ở https://github.com/new (để trống, không README, nên Private) rồi `git remote set-url origin <url repo mới>`. Cách thay thế: trên trang repo template bấm **Use this template** > **Create a new repository**, rồi clone repo mới của bạn; khi đó `origin` đã là repo của bạn từ đầu.

Cấu trúc đáng biết: `AGENTS.md` là luật agent; `docs/brief.md`, `decisions.md`, `plan.md`, `progress.md` là bộ nhớ của dự án (agent điền dần, phiên sau đọc lại); `.codex/` và `.claude/` là cấu hình và lớp chặn; `.agents/skills/` là các quy trình con (kickoff, security-check, deploy, backup). App sẽ được scaffold vào `app/` ở mốc 1, không dựng thẳng vào gốc repo vì `npm create vite` trong thư mục không trống có thể đề nghị xoá file có sẵn.

Trust dự án và duyệt hook

Mở **thư mục gốc** của repo bằng Codex và hỏi "mình mới clone về, hướng dẫn mình bắt đầu". Agent chạy `git --version`, `node --version`, kiểm hook và `origin`, rồi chỉ phần còn thiếu. Phần dưới là chi tiết của các bước đó. Lần đầu Codex hỏi có trust thư mục không: chọn trust. Codex chỉ nạp layer `.codex/` của dự án (config, rules, hooks) khi dự án đã được trust. Nguồn: https://learn.chatgpt.com/docs/config-file/config-basic.

Hook là script Codex chạy trước mỗi tool call; ở đây là `.codex/hooks/guard.mjs`, đọc lệnh shell và chặn nếu phá huỷ. Vì hook là code chạy trên máy bạn, Codex bắt duyệt nó một lần và duyệt lại khi file đổi (trust theo hash). Trong terminal của VS Code chạy `codex`, gõ `/hooks`, xem hook rồi trust. Nguồn: https://learn.chatgpt.com/docs/hooks. Bộ khung chưa thử màn này trên Windows, nên kiểm lại: nhờ agent chạy `echo ai-app-starter-guard-check`. Bị chặn với chữ "Hook đang chạy" là hook đã nạp; in ra chữ đó bình thường là chưa trust dự án hoặc chưa duyệt hook. Lệnh này vô hại trong cả hai trường hợp. Có thể tự kiểm thêm bằng `node --test .codex/hooks/guard.test.mjs` và `node scripts/check-guards.mjs`.

Câu đầu tiên và cách trả lời

Kể ý tưởng là đủ, vd "Mình muốn làm app ghi chi tiêu cá nhân." Agent hỏi lại tối đa sáu câu, mỗi câu có lựa chọn đánh chữ. Lần thử ngày 04/11/2026, Codex hỏi về người dùng, đăng nhập và đồng bộ, dữ liệu mỗi khoản chi, tính năng xem lại, thiết bị, và câu cuối:

> **6. Bạn muốn mình làm đến mức nào?** (a) Mình làm hết, bạn đọc và chạy thử; (b) Bạn tự viết giao diện để học; (c) Bạn tự viết phần truy vấn database để học; (d) Khác: ...

Trả lời ngắn kiểu "1a, 2b, 3b, 4a, 5a, 6b", thêm chi tiết nếu muốn. Agent ghi `docs/brief.md` rồi đề xuất. Trích đề xuất thật ở lần thử đó:

> Giao diện gửi dữ liệu trực tiếp đến Supabase, dùng **RLS (quy tắc giới hạn từng người được đọc/sửa dòng nào)** để bảo vệ dữ liệu. Cách này ít code hơn tự viết API, đổi lại phải kiểm policy cẩn thận. [...] Bạn tự viết giao diện ở mốc sau khi khung local chạy được. Mình sẽ chuẩn bị kiểu dữ liệu, khung component và `TODO` ghi rõ input/output, rồi review code bạn làm.

Đây là lúc rẻ nhất để đổi ý. Hỏi vặn thoải mái: "vì sao không dùng Next.js", "nếu 1.000 người dùng thì tốn bao nhiêu", "bỏ auth cho mốc đầu được không". Đồng ý thì nói rõ "Mình đồng ý"; agent ghi `docs/decisions.md`, lập `docs/plan.md` và cho bạn xem plan trước khi làm mốc 1.

Mỗi mốc diễn ra thế nào

Agent viết code cho đúng mốc, tự chạy `npm run build` (và test, lint nếu có), mốc có giao diện thì xem cả khổ điện thoại 360×780 lẫn desktop, commit, rồi báo: đã làm gì, 2–4 file chính nên đọc kèm một câu mỗi file làm gì, cách tự kiểm, còn gì chưa làm. Phần bạn chọn tự viết, agent dựng khung, để `TODO` có mô tả input/output, giải thích việc cần làm và chờ bạn; xong thì nhờ agent review.

Đọc các file agent chỉ ra, đặc biệt migration SQL và RLS policy: đó là phần dễ sai nhất và đáng học nhất. Chạy thử thật sau mỗi mốc; agent có thể báo "xong" khi một nút chưa chạy. Phiên hôm sau, agent đọc `docs/progress.md` trước và tóm tắt lần trước làm tới đâu.

Quyền của agent: khi nào phải dừng đọc kỹ

Codex có hai lớp: **sandbox** giới hạn file và mạng agent được dùng; **approval policy** quyết định khi nào agent phải hỏi. `.codex/config.toml` đặt `sandbox_mode = "workspace-write"` (chỉ ghi trong dự án; `.git`, `.codex`, `.agents` luôn chỉ đọc) và `approval_policy = "on-request"` (hỏi khi cần vượt sandbox, vd dùng mạng cho `npm install`). Vì `.git` chỉ đọc, `.codex/rules/default.rules` cho phép sẵn `git add` và `git commit` chạy ngoài sandbox để commit mỗi mốc không phải bấm duyệt; `git push` vẫn hỏi. Nguồn: https://learn.chatgpt.com/docs/agent-approvals-security, https://learn.chatgpt.com/docs/agent-configuration/rules.

Trong app và extension, nút chọn chế độ quyền nằm dưới ô nhập. Dùng **Ask for approval**. **Approve for me** gửi yêu cầu duyệt cho một hệ thống review tự động, ranh giới sandbox giữ nguyên. Không dùng **Full access**: agent không còn bị giới hạn trong dự án. Nguồn: https://learn.chatgpt.com/docs/permission-modes.

Khi có hộp hỏi duyệt, đọc lệnh, thư mục chạy và có cần mạng không. Phần lớn là bình thường (`npm install`, `npx supabase migration new`). Dừng lại hỏi agent "lệnh này làm gì" khi thấy:

- **Tốn tiền**: nâng gói, gắn thẻ, bật dịch vụ trả phí.
- **Mất dữ liệu**: xoá ngoài `node_modules` / `dist` / `build`; `DROP`, `TRUNCATE`, `DELETE`; `db reset`; `--force`.
- **Ra công khai**: `git push` (với Cloudflare Pages, push lên nhánh chính là deploy), đổi repo sang public, gửi email thật.
- **Key và tài khoản**: tự dán key vào `.env`, không dán vào chat.
- **Ra ngoài dự án**: đường dẫn bắt đầu bằng `C:\`, `~`, `..`.

Luật trong `AGENTS.md` đã bắt agent tự dừng ở các trường hợp này; hộp duyệt là lớp thứ hai, bạn là lớp cuối.

Giới hạn miễn phí và mốc trả tiền

Kiểm ngày 04/11/2026; nguồn ở cột cuối.

Dịch vụ	Miễn phí tới đâu	Mốc trả tiền	Nguồn
Supabase Free	DB 500 MB; storage 1 GB; file tối đa 50 MB; 50.000 MAU; egress 5 GB; Edge Functions 500.000 lần; 2 project active. **Tự pause sau 1 tuần không hoạt động, không backup.**	Pro từ $25/tháng (gồm $10 compute credit)	supabase.com/pricing
Cloudflare Pages	500 build/tháng; asset tĩnh miễn phí	Workers Paid từ $5/tháng khi cần nhiều code phía server	developers.cloudflare.com/pages/platform/limits
Cloudflare Workers Free	100.000 request/ngày, 10 ms CPU mỗi lần	Workers Paid từ $5/tháng	developers.cloudflare.com/workers/platform/pricing
Cloudflare R2	10 GB-tháng; 1 triệu Class A, 10 triệu Class B; egress $0	$0,015/GB-tháng phần vượt; phải bật gói R2 qua bước thanh toán	developers.cloudflare.com/r2/pricing
Vercel Hobby	100 GB transfer/tháng; chỉ dùng cá nhân, phi thương mại	Pro $20/tháng	vercel.com/pricing
Resend Free	3.000 email/tháng, 100 email/ngày	Pro $20/tháng	resend.com/pricing
Google Drive	Tài khoản tạo từ 09/03/2026: 5 GB, thêm 10 GB khi xác minh số điện thoại	Google One	support.google.com/drive/answer/2375123

Hệ quả cho việc chọn stack:

- **Vercel Hobby không dùng cho app thương mại** ("for personal, non-commercial use"), nên mặc định là Cloudflare Pages.
- **Supabase Free tự pause** khi một tuần không hoạt động, và **không có backup**: lỡ chạy sai migration trên prod là mất. Vì vậy có hai project dev/prod và script sao lưu.
- **R2** chỉ cần khi tổng file vượt khoảng 1 GB (mức storage của Supabase Free). Theo tài liệu Cloudflare phải bật gói R2 qua bước checkout; diễn đàn Cloudflare cho biết bước này đòi phương thức thanh toán dù dùng trong mức free.
- **Google Drive** chỉ hợp kiểu "lưu vào Drive của chính người dùng" với scope `drive.file` (app chỉ thấy file nó tạo hoặc người dùng chọn; Google xếp non-sensitive). Scope `drive` là restricted, xét

duyệt nặng. Không dùng Drive làm kho chính. Nguồn: https://developers.google.com/workspace/drive/api/guides/api-specific-auth.

Hai sự cố có thật và cách bộ khung chặn

Lovable và RLS bị thiếu (2025)

Lovable là công cụ tạo app bằng AI, dùng Supabase làm backend. Đầu năm 2025, Matt Palmer quét các app trên trang Lovable Launched: theo bài công bố, 170 trên 1.645 project (khoảng 10,3%) có 303 endpoint để lộ dữ liệu vì RLS thiếu hoặc sai. Dữ liệu lộ gồm tên, số điện thoại, email, thông tin thanh toán, API key dịch vụ khác; ở một app còn ghi được dữ liệu (chèn bản ghi "đã thanh toán" để bỏ qua Stripe). Mã lỗi CVE-2025-48757, công bố 29/05/2025. Nguồn: https://mattpalmer.io/posts/statement-on-CVE-2025-48757/.

Cơ chế: frontend gọi Supabase (PostgREST) thẳng bằng publishable key, key này công khai theo thiết kế. Request chạy với role `anon` hoặc `authenticated`, và thứ duy nhất giới hạn dòng nào đọc được là RLS policy. Bảng không bật RLS, hay policy kiểu `using (true)`, thì ai cầm key cũng `select=*` được cả bảng. Nguồn: https://supabase.com/docs/guides/database/postgres/row-level-security.

Bộ khung chặn bằng: luật bắt bật RLS ngay trong migration tạo bảng, `revoke all` khỏi `anon` / `authenticated` rồi grant lại đúng quyền, policy theo `auth.uid()`; skill `security-check` có SQL tìm bảng chưa bật RLS, liệt kê grant, policy, view thiếu `security_invoker`, hàm `SECURITY DEFINER`, policy của Storage, và bắt thử bằng hai tài khoản; hook chặn lệnh tắt RLS; `service_role` key không bao giờ nằm trong frontend.

Replit xoá database thật (07/2025)

Tháng 7/2025, Jason Lemkin (SaaStr) kể agent của Replit đã xoá database production trong lúc ông yêu cầu đóng băng code, bỏ qua chỉ dẫn và tạo dữ liệu giả. CEO Replit gọi sự việc là "không thể chấp nhận". Theo blog Replit được The Register trích, app trên Replit trước đó dùng chung một database cho dev và dữ liệu khách hàng thật; sau sự cố Replit bắt đầu tách dev/prod tự động. Nguồn: https://www.theregister.com/2025/07/22/replit_saastr_response/.

Bài học: agent có thể làm sai dù đã được dặn, nên điều chắc chắn duy nhất là agent không có đường tới dữ liệu thật. Bộ khung làm vậy theo nhiều lớp:

- **Hai project Supabase**: agent chỉ link với dev. Connection string prod không nằm trong repo hay `.env`. Đưa migration lên prod là bạn tự chạy `supabase db push --db-url` trong terminal của mình (skill deploy), sau khi đã thử trên dev.
- **MCP Supabase** (nếu dùng) chỉ trỏ vào dev với `read_only=true` và `project_ref`. Nguồn: https://supabase.com/docs/guides/getting-started/mcp.
- **Hook và rules** chặn `DROP`, `TRUNCATE`, `DELETE` không `WHERE`, `supabase db reset --linked`, xoá tài nguyên cloud, `git reset --hard`, push ép. Lần thử 04/11/2026 (trên macOS, chưa thử Windows), Codex bị chặn khi chạy `rm -rf scripts` và `git reset --hard`, file còn nguyên.
- **Sao lưu**: `scripts/backup-supabase.mjs`, agent nhắc chạy sau mỗi thay đổi schema và hằng tuần.

Hook và rules đọc chữ của lệnh, nên một script tự xoá file hay SQL nằm trong file có thể lọt. Đó là lưới chống nhầm, không phải ranh giới bảo mật. Lớp quan trọng nhất vẫn là không đưa credential prod cho agent.

Sự cố hay gặp và cách gỡ

Supabase báo project bị pause

Gói Free pause project sau một tuần không hoạt động; app báo lỗi kết nối. Vào https://supabase.com/dashboard, mở project, bấm restore và chờ vài phút. Project dev hay bị pause nhất; nếu prod có người dùng thật mà vẫn bị pause thường xuyên, đã tới lúc cân nhắc Pro.

Hết hạn mức Codex

Codex tính hạn mức theo khung 5 giờ và theo tuần, xem ở trang usage của tài khoản. Hết giữa chừng thì lượt đang chạy vẫn được làm nốt; sau đó chờ reset hoặc mở cùng dự án bằng Claude Code. Để đỡ tốn: mỗi lượt giao một việc rõ ("làm mốc 3 trong plan"), mở phiên mới khi đổi việc, chỉ dán đoạn log có lỗi.

Lỗi build

Lỗi `npm run build` trên máy: dán vài dòng có `error` cho agent. Lỗi khi Cloudflare Pages build: Cloudflare > dự án > **Deployments** > bản lỗi > **View build log**. Máy build được mà Cloudflare lỗi thường do thiếu biến `VITE_*` trong Environment variables của dự án, hoặc sai **Root directory** (phải là `app`). Bản deploy mới hỏng: **Deployments** > bản cũ > **Rollback**.

Agent đi lạc, muốn quay lại bản trước

Mỗi mốc là một commit, nên luôn có điểm quay về:

- **Chưa commit, bỏ thay đổi một file**: Source Control trong VS Code > chuột phải file > **Discard Changes**.
- **Huỷ một commit**: nhờ agent `git revert <commit>`; lịch sử vẫn đủ.
- **Thử lại từ mốc cũ**: nhờ agent tạo nhánh mới từ commit đó; nhánh hiện tại giữ nguyên.

Bộ khung chặn agent chạy `git reset --hard` và `git push --force` vì chúng xoá thay đổi hay lịch sử. Cần thật thì bạn tự chạy sau khi hiểu nó làm gì.

Sao lưu và thử phục hồi database

Mở Docker Desktop (Supabase CLI chạy `pg_dump` trong container). Lấy connection string của project dev ở Supabase > **Connect** > **Session pooler**, điền `SUPABASE_DEV_DB_URL` trong `.env` (mật khẩu có ký tự đặc biệt thì percent-encode, `@` thành `%40`). Rồi:

```
node scripts/backup-supabase.mjs --dry-run
node scripts/backup-supabase.mjs
```

Lệnh đầu in lệnh sẽ chạy và project ref, mật khẩu được che. Lệnh sau tạo `backups/<ngày_giờ>-dev/` gồm `roles.sql`, `schema.sql`, `data.sql`; thư mục này nằm trong `.gitignore`, chép ra chỗ an toàn. Bản sao lưu không gồm file trong Storage (chỉ có dòng metadata). Prod thì tự chạy với `--prod`, đặt connection string prod chỉ trong cửa sổ PowerShell đó (xem `.agents/skills/backup-supabase/SKILL.md`). Thử phục hồi ít nhất một lần vào một project dev trống theo hướng dẫn chính

thức: https://supabase.com/docs/guides/platform/migrating-within-supabase/backup-restore. Script đã chạy `--dry-run` trên macOS; lần chạy thật đầu tiên trên Windows hãy đọc kỹ output.

Lỡ để lộ key

Lỡ dán key vào chat, commit `.env`, hay push secret: coi như key đã lộ. Tạo key mới và thu hồi key cũ trên dashboard (Supabase > Project Settings > API keys, hay trang key của dịch vụ đó), cập nhật `.env` và biến môi trường trên Cloudflare. Xoá file khỏi git không đủ vì lịch sử vẫn giữ bản cũ.

Thuật ngữ của stack

Từ	Nghĩa ngắn
`AGENTS.md`	File luật Codex đọc đầu mỗi phiên (Claude Code đọc qua `CLAUDE.md`)
Migration	File SQL ghi từng thay đổi schema, chạy theo thứ tự (`supabase/migrations/`)
RLS, policy	Row Level Security: luật Postgres quyết định role nào đọc/ghi dòng nào
`anon`, `authenticated`	Role Postgres của request chưa / đã đăng nhập qua Supabase
Publishable key	Key công khai cho frontend; chỉ an toàn khi RLS đúng
Secret / `service_role` key	Key bỏ qua RLS; chỉ dùng phía server, không bao giờ trong frontend
`VITE_*`	Biến env Vite nhúng vào bundle frontend, ai cũng đọc được
Dev / prod	Project để làm và thử / project có người dùng thật
Sandbox, approval	Ranh giới file/mạng của agent / khi nào agent phải hỏi
Hook, rules	Script chạy trước mỗi lệnh của agent / luật cấm, hỏi theo đầu lệnh
PWA, service worker	Web app cài được như app (manifest + icon) / script trình duyệt cache asset, chạy nền
MCP	Giao thức nối agent với dịch vụ ngoài (database, Cloudflare…)

Nguồn

Kiểm ngày 04/11/2026.

- Vite PWA: https://vite-pwa-org.netlify.app/guide/, https://vite-pwa-org.netlify.app/guide/pwa-minimal-requirements.html, https://vite-pwa-org.netlify.app/assets-generator/cli.html.
- Codex: Windows https://learn.chatgpt.com/docs/windows/windows-app, https://learn.chatgpt.com/docs/windows/windows-sandbox; quyền https://learn.chatgpt.com/docs/permission-modes, https://learn.chatgpt.com/docs/agent-approvals-security; cấu hình https://learn.chatgpt.co

m/docs/config-file/config-basic; hooks https://learn.chatgpt.com/docs/hooks; rules https://learn.chatgpt.com/docs/agent-configuration/rules; AGENTS.md https://learn.chatgpt.com/docs/agent-configuration/agents-md; IDE https://learn.chatgpt.com/docs/ide; CLI https://github.com/openai/codex.

- Claude Code: bộ nhớ và `AGENTS.md` https://code.claude.com/docs/en/memory; permissions https://code.claude.com/docs/en/permissions; hooks https://code.claude.com/docs/en/hooks.
- Supabase: giá https://supabase.com/pricing; RLS https://supabase.com/docs/guides/database/postgres/row-level-security; MCP https://supabase.com/docs/guides/getting-started/mcp; sao lưu https://supabase.com/docs/guides/platform/migrating-within-supabase/backup-restore.
- Cloudflare: Pages https://developers.cloudflare.com/pages/platform/limits/; Workers https://developers.cloudflare.com/workers/platform/pricing/; R2 https://developers.cloudflare.com/r2/pricing/, https://developers.cloudflare.com/r2/get-started/.
- Vercel: https://vercel.com/pricing, https://vercel.com/docs/plans/hobby. Resend: https://resend.com/pricing.
- Google Drive: https://developers.google.com/workspace/drive/api/guides/api-specific-auth, https://support.google.com/drive/answer/2375123.
- Sự cố: Lovable https://mattpalmer.io/posts/statement-on-CVE-2025-48757/; Replit https://www.theregister.com/2025/07/22/replit_saastr_response/.